TLP:CLEAR

INCIDENT REPORT

WhatsApp Account Takeover via "Defisher" Phishing Kit

WhatsApp Device Linking • Phishing Kit • PhaaS • Bulletproof Hosting • Aeza Group

Parameter	Value
Incident Date	**March 4, 2026**
Analysis Date	**March 5–6, 2026**
Classification	**Account Takeover / WhatsApp Device Linking**
Threat Level	**HIGH**
Attack Vector	**Phishing link via Signal messenger**
Tool	**"Defisher" phishing kit (PhaaS platform, Next.js)**
Hosting	**AEZA GROUP (AS210644)** — bulletproof hosting, US OFAC sanctions
Status	**Active at time of analysis (2026-03-06)**

1. Executive Summary

The victim received a link via Signal messenger leading to a phishing site at trust-authorization[.]tech. The site impersonated the WhatsApp Web interface and prompted the victim to enter their phone number. After entering the number, the victim was shown an 8-digit device linking code with instructions to enter it in WhatsApp settings.

As a result, the attacker's device was linked to the victim's WhatsApp account. In addition to real-time message access, WhatsApp automatically synchronizes recent message history (including photos, videos, and documents) to newly linked devices. This means the attacker gained access to both new messages and the message archive.

The phishing kit was identified as "Defisher" — a commercial Phishing-as-a-Service (PhaaS) platform built on Next.js with a multi-user admin panel, domain/proxy management, and hijacked session export. The infrastructure is hosted on an AEZA Group server (AS210644) — a Russian bulletproof hosting provider under US OFAC sanctions since July 2025.

Active testing (March 6, 2026) confirmed the server remains operational. The kit's built-in CIS country phone number filtering was not activated by the operator — numbers from Russia, Ukraine, Kazakhstan, and Belarus were accepted alongside foreign numbers.

2. Attack Mechanism

2.1. Attack Chain

The attack exploits WhatsApp's legitimate "Linked Devices" feature, which allows linking additional devices to an account using an 8-digit code. The phishing kit automates obtaining this code through server-side interaction with the WhatsApp API.

- Victim receives a link via Signal (or another messenger)
- Clicking the link loads a Next.js application impersonating WhatsApp Web
- The page automatically detects the victim's country via ipapi.co
- Victim enters their phone number
- The number is sent via WebSocket (Socket.IO) to the C2 server panel-my-test[.]online
- The server initiates the device linking procedure and obtains an 8-digit code
- The code is displayed to the victim with instructions: "Open WhatsApp → Linked Devices → Link a Device → Link with phone number instead → Enter this code"
- Victim enters the code — the attacker's device is linked to the account
- WhatsApp automatically synchronizes recent message history to the attacker's device

2.2. Social Engineering

The phishing page was designed as a channel called "Report channel" (16 subscribers) with a stock photo avatar of a person writing on paper. A Signal user receiving the link could perceive it as a verification request or a feedback channel invitation.

The page precisely reproduces the WhatsApp Web interface: logo, color scheme (#008069), typography. The HTML page title is "WhatsApp".

2.3. CIS Filtering: Code Present, Filter Disabled

The kit's client-side code contains a handler for blocking phone numbers from CIS countries:

socket.on("sng", () => { error = "Извините, ваш номер в зоне СНГ, ошибка." })

However, active testing (March 6, 2026) via the WebSocket API demonstrated that the filter is not active in this campaign. Numbers from Russia (+7), Ukraine (+380), Kazakhstan (+7), and Belarus (+375) were accepted by the server, and a real 8-digit WhatsApp linking code was generated for each. The "sng" event was never received.

CIS geo-filtering is a built-in option of the Defisher kit, implemented server-side. The operator of this campaign did not activate it. This is likely a configurable setting in the admin panel.

Russian-language strings in the code ("Извините, ваш номер в зоне СНГ" [Sorry, your number is in the CIS zone], "Ошибка определения страны" [Country detection error], the panel's 404 page) indicate a Russian-speaking kit developer, but not necessarily a Russian-speaking campaign operator.

3. Phishing Kit "Defisher"

3.1. Technology Stack

Component	Technology
Frontend	Next.js (React), Tailwind CSS, Radix UI
Backend	Node.js, Socket.IO (WebSocket)
Admin Panel	Next.js (separate build, /auth)
Proxy	Nginx Proxy Manager v2.14.0 + OpenResty
GeoIP	ipapi.co
Authentication	JWT in cookies

3.2. Operating Modes

The kit supports two account hijacking modes:

- QR code — generates a WhatsApp Web QR code for the victim to scan
- Phone number — obtains an 8-digit device linking code (used in this incident)

3.3. Capabilities

- Configurable pretext: title, photo, subscriber count
- Geo-filtering: optional CIS number blocking (not active in this campaign)
- Optional confirmation page with custom text and image
- Error management: showerror parameter — on error, display "Verification completed!" instead of an error message
- Statistics: view count, number input count, successful linking count
- Optional redirect after successful linking
- Domain and proxy management via API
- Hijacked session export (account archives)

3.4. PhaaS Platform

Reverse engineering of the admin panel's JavaScript code revealed a full-featured Phishing-as-a-Service platform with multi-user architecture:

Category	Functionality
User Management	Create/delete/ban users, change passwords (admin role)
Campaigns	Create/delete templates (campaigns), generate API keys
Domains & Proxies	Bind domains and proxies to users, create via API
Sessions	View/download/delete hijacked accounts (archives)
Settings	Redirect URL, error type — configurable per user
Authentication	JWT, role-based model (admin/user), Russian-language error messages

Defisher is not a single-operator tool but a service provided to multiple users. Each user manages their own campaigns, domains, and hijacked sessions independently.

3.5. Language Markers

The code contains Russian-language strings indicating a Russian-speaking developer:

- "Извините, ваш номер в зоне СНГ, ошибка." (Sorry, your number is in the CIS zone) — CIS filtering
- "JWT токен не найден в куки" (JWT token not found in cookies), "Неверные логин или пароль" (Invalid login or password) — authentication
- "Ошибка определения страны" (Country detection error) — geolocation
- "404 - Страница не найдена" (Page not found), "На главную" (Go to homepage) — admin panel
- "Полученные домены:" (Received domains), "Ошибка при создании доменов через API:" (Error creating domains via API) — debug logging

3.6. Campaign API and Statistics

An open API endpoint /api/content/get exposes the phishing page's configuration and statistics:

Parameter	Value	Description
id	8	Campaign sequence number on the server
type	wame	WhatsApp ME — attack type
auth	phone	Mode: phone number-based device linking
viewCount	210	Page view count
numberInputCount	73	Phone number input count
validCount	0	Successful linking count (kit metric)
wameTitle	Report channel	Lure channel name
wameSubscribers	16	Fake subscriber count
showerror	off	Do not show errors to the victim

timestamp	2026-03-04T06:58:41Z	Campaign creation date

Campaign id=8 means at least 8 phishing campaigns have been created on this server. The view-to-input conversion rate was 34.8% (73 out of 210) — a high rate characteristic of targeted distribution via messenger.

4. Infrastructure

4.1. Server

Parameter	Value
IP Address	147.45.43[.]133
ASN	AS210644 (AEZA-AS)
Provider	Aeza International LTD
RIPE Handle	ORG-AGL38-RIPE
Legal Entity (UK)	311 Shoreham Street, Sheffield, S2 4FA, United Kingdom
Legal Entity (RU)	AEZA GROUP LLC, Room 1N, Office 603, Hse 15, Bldg 1, Zolnaya St., SPb 193318, RU
Abuse Contact	support@my-aeza[.]net
Netblock	147.45.43.0/24 (Aeza-Network), created 2024-01-09
Server Location	Frankfurt, DE
OS	Ubuntu (OpenSSH 9.6p1-3ubuntu13.5)
Web Stack	OpenResty + Nginx Proxy Manager v2.14.0
Censys Labels	BULLETPROOF

AEZA Group operates through two legal entities: Aeza International LTD (UK, Sheffield) and AEZA GROUP LLC (RU, St. Petersburg). Classified as bulletproof hosting. In April 2025, AEZA offices were raided by the FSB. In July 2025, AEZA was added to the US OFAC sanctions list for providing infrastructure to cybercriminals.

4.2. Infrastructure Timeline

Date/Time (UTC)	Event
2026-02-17 05:32	Nginx Proxy Manager installed on VPS (port 80 Last-Modified)
2026-02-17 05:33	NPM admin panel configured (port 81 Last-Modified)
	↓ 13 days — Defisher setup, backend configuration
2026-03-02 06:30:09	trust-authorization[.]tech registered (PDR Ltd.)
2026-03-02 06:30:17	panel-my-test[.]online registered (PDR Ltd.) [+8 sec]
2026-03-02 06:49	TLS certificates issued (CT log entry_timestamp)
	↓ 2 days — campaigns #1–7 setup
2026-03-04 06:58	Campaign #8 created (current incident)
2026-03-04	Phishing links distributed via Signal

2026-03-05	Incident discovered, analysis begins
2026-03-06 06:11	Active testing: server still operational

The operator set up the VPS 13 days before registering domains, indicating a preparatory phase: Defisher installation, backend configuration, testing. Domains were batch-registered and connected to the ready server within minutes.

4.3. Domains

Domain	Purpose	Registration
trust-authorization[.]tech	Phishing page	2026-03-02T06:30:09Z
panel-my-test[.]online	Admin panel + WebSocket API	2026-03-02T06:30:17Z

Both domains were registered 8 seconds apart (batch registration) via PDR Ltd. (PublicDomainRegistry.com). DNS servers: ns1-4.timeweb.ru/org (Timeweb, a Russian hosting provider). WHOIS hidden behind IDCPrivacy Service. Let's Encrypt certificates appeared in Certificate Transparency logs 19 minutes after domain registration.

4.4. Ports and Services

Port	Service	Purpose	Last-Modified
22/tcp	OpenSSH 9.6p1	Server administration	—
80/tcp	Nginx Proxy Manager + OpenResty	Default page / HTTPS redirect	2026-02-17 05:32
81/tcp	Nginx Proxy Manager v2.14.0	NPM panel (exposed to internet)	2026-02-17 05:33
443/tcp	OpenResty (TLS)	Phishing pages + API	—

Port 81 exposes the Nginx Proxy Manager admin panel to the internet without authentication over HTTP. The API returns version information (2.14.0) and status. Default credentials have been changed.

4.5. DNS Records for trust-authorization[.]tech

Type	Value
A	147.45.43[.]133
MX	10 mx1.timeweb.ru, 20 mx2.timeweb.ru
TXT	v=spf1 include:_spf.timeweb.ru ~all
NS	ns1-4.timeweb.ru/org

5. Active Testing (March 6, 2026)

To verify kit functionality and CIS filtering behavior, active testing was conducted via the WebSocket API (Socket.IO connection to panel-my-test[.]online/api/socket). Known-invalid phone numbers were used for testing.

5.1. Test Results

Number	Country	CIS?	Result
+48512000000	Poland	No	Linking code received
+79510000000	Russia	Yes	Linking code received
+380501000000	Ukraine	Yes	Linking code received
+77010000000	Kazakhstan	Yes	Linking code received
+375291000000	Belarus	Yes	Linking code received
+48999000111	(invalid format)	—	phone-number-error
+11234567890	USA (invalid)	—	phone-number-error

5.2. Testing Conclusions

- CIS filter is not active — all CIS country numbers (RU, UA, KZ, BY) were accepted by the server, with real WhatsApp linking codes generated for each
- Number validation is performed by the WhatsApp API — invalid format numbers are rejected with phone-number-error
- Linking codes are real: the server interacts with the WhatsApp API and obtains genuine linking codes, confirming full kit functionality
- CIS geo-filtering is an optional server-side setting of the Defisher kit, not activated by this campaign's operator

6. Indicators of Compromise (IOC)

6.1. Network Indicators

Type	Value	Description
Domain	trust-authorization[.]tech	Phishing page
Domain	panel-my-test[.]online	C2 panel / WebSocket API
IP	147.45.43[.]133	Server (Aeza, AS210644, Frankfurt)
ASN	AS210644	AEZA-AS, bulletproof hosting
Netblock	147.45.43[.]0/24	Aeza-Network
URL	hxxps://trust-authorization[.]tech/pUsl9nuZo649dKua0HL7uG5npbYAq1bn	Phishing link
URL	hxxps://panel-my-test[.]online/api/socket	WebSocket endpoint
URL	hxxps://panel-my-test[.]online/auth	Defisher admin panel

6.2. TLS Certificates

Domain	Issuer	Serial	CT Log Timestamp
trust-authorization[.]tech	Let's Encrypt E7	0571f6a08d8bad...012108	2026-03-02 ~06:49 UTC
panel-my-test[.]online	Let's Encrypt E8	06390e30192e87...4a46	2026-03-02 ~06:49 UTC

6.3. SSH Fingerprints

Type	Value
HASSH	e42184b06d45385a906f0803d04c83da
Host Key SHA256	67e1fe70de94c56a515ae423ac6eded53e98a20cc7732114f661b372de82f934

6.4. Next.js Build IDs

Component	Build ID
Phishing page	U2cF4qdrSAKoVe_6ATRWM
Admin panel	wNL_QTpqVok6FnMxIeW9R

7. MITRE ATT&CK

ID	Technique	Application in Incident
T1566.002	Spearphishing Link	Link sent via Signal messenger

T1078	Valid Accounts	WhatsApp session hijack via device linking
T1583.001	Acquire Infrastructure: Domains	Registration of trust-authorization[.]tech + panel-my-test[.]online
T1583.003	Acquire Infrastructure: VPS	Bulletproof hosting on AEZA (AS210644)
T1588.002	Obtain Capabilities: Tool	PhaaS platform "Defisher"
T1036.005	Match Legitimate Name	WhatsApp Web interface impersonation
T1071.001	Application Layer Protocol: Web	WebSocket (Socket.IO) for C2 communication
T1530	Data from Cloud Storage	Message access via linked device

8. Recommendations

8.1. Immediate Actions

- Remove unknown device: WhatsApp → Settings → Linked Devices → remove suspicious device
- Review all linked devices and remove any unrecognized ones
- Enable two-step verification: Settings → Account → Two-step verification
- Notify contacts about potential message compromise

8.2. Damage Assessment

From the moment of device linking until removal, the attacker had access to all incoming and outgoing messages in real time. A WhatsApp linked device receives messages synchronously with the primary device.

In addition to new messages, WhatsApp automatically synchronizes recent message history (including photos, videos, and documents) when linking a new device. The primary phone transmits an encrypted package of recent messages to the new device, where they are decrypted and stored locally. The volume of synchronized history depends on the device type.

Therefore, the attacker could have gained access not only to messages received after compromise, but also to the archive of earlier conversations.

8.3. Preventive Measures

- Do not click links from unverified sources, even if received through secure messengers
- Never enter device linking codes on third-party websites
- Regularly check the list of linked devices in WhatsApp
- Enable WhatsApp two-step verification (6-digit PIN)

8.4. For SOC/Security Teams

- Block domains trust-authorization[.]tech and panel-my-test[.]online
- Monitor the 147.45.43[.]0/24 netblock (Aeza) — similar instances are likely
- Search URLScan/CT logs for other domains matching the pattern: Timeweb NS + PDR registrar + Aeza hosting
- Next.js Build ID U2cF4qdrSAKoVe_6ATRWM may appear on other phishing domains by the same operator

TLP:CLEAR — This document may be distributed without restriction.